ENIGMA DARK

Securing the Shadows

Security Review

Aave v3.7 Upgrade

Report produced for Aave DAO
Code developed by BGD Labs

March, 2026

Contents

1. Summary
2. Engagement Overview
3. Risk Classification
4. Vulnerability Summary
5. Findings
6. Disclaimer

Summary

Enigma Dark
Enigma Dark is a web3 security firm leveraging the best talent in the space to secure all kinds of blockchain protocols and decentralized apps. Our team comprises experts who have honed their skills at some of the best auditing companies in the industry. With a proven track record as highly skilled white-hats, they bring a wealth of experience and a deep understanding of the technology and the ecosystem.

Learn more about us at enigmadark.com

BGD Labs
BGD Labs is a Web3 development initiative and one of the main Aave contributors, responsible for the protocol's ongoing maintenance and the introduction of new, innovative features. Comprised of a team of expert developers with deep experience in Ethereum, more precisely in Decentralized Finance (DeFi), governance token modeling/economics.

AAVE v3.7 Protocol Upgrade
AAVE is one of the leading lending and borrowing platforms in DeFi, allowing users to supply and borrow assets with variable interest rates. The Aave v3.7 upgrade includes the following changes and features:

- Introduction of isolated eModes via a new `bool isolated` flag on eMode categories, automatically treating non-eMode collateral as LTV-zero and replacing manual `ltvzeroBitmap` maintenance.
- Removal of Isolation Mode (debt ceilings) and Siloed Borrowing, superseded by the more flexible v3.6 specialized eModes.
- Removal of the PriceOracleSentinel and SequencerOracle contracts that gated L2 borrows and liquidations on sequencer uptime.
- Removal of the `dropReserve` functionality to prevent ecosystem-breaking reserve ID reuse.
- Deterministic liquidation rounding fixes replacing half-up rounding with explicit floor/ceil variants.

Engagement Overview

Over the course of 1 week, beginning March 6 2026, the Enigma Dark team conducted a security review of the AAVE v3.7 Protocol Upgrade project. The review was performed by two Lead Security Researchers: vnmrtz & Lambda.

The following repositories were reviewed at the specified commits:

Repository	Commit
aave-dao/aave-v3-origin	`diff 1e3d70c...75145ad`

Review Scope

The scope is limited to the core contracts inside:

```
src/contracts/
├── interfaces/*
└── protocol/*
```

Risk Classification

Severity	Description
Critical	Vulnerabilities that lead to a loss of a significant portion of funds of the system.
High	Exploitable, causing loss or manipulation of assets or data.
Medium	Risk of future exploits that may or may not impact the smart contract execution.
Low	Minor code errors that may or may not impact the smart contract execution.
Informational	Non-critical observations or suggestions for improving code quality, readability, or best practices.

Vulnerability Summary

Severity	Count	Fixed	Acknowledged
Critical	0	0	0
High	0	0	0
Medium	0	0	0
Low	1	1	0
Informational	1	1	0

Findings

Index	Issue Title	Status
L-01	Incorrect `hasNoCollateralLeft` detection due to `rayDivCeil` rounding	Fixed
I-01	Minor improvements to code and comments	Fixed

Detailed Findings

High Risk

No issues found.

Medium Risk

No issues found.

Low Risk

L-01 - Incorrect `hasNoCollateralLeft` detection due to `rayDivCeil` rounding

Severity: Low

Context: LiquidationLogic.sol#L318-L398

Technical Details:

After reviewing the fix 201aaa6, we noticed that the `hasNoCollateralLeft` flag is not correctly detected.

The `hasNoCollateralLeft` flag in `LiquidationLogic` is derived by comparing unscaled base-currency values: `totalCollateralInBaseCurrency == collateralToLiquidateInBaseCurrency`. However, this check can disagree with the actual post-transfer outcome, a scenario exists where `hasNoCollateralLeft` evaluates to `false`, yet the user's scaled collateral balance reaches zero after the liquidation transfers are executed.

BGD identified the root cause: the actual token operations use `rayDivCeil` independently for both the liquidator transfer and the protocol fee transfer. The sum of these ceil-rounded scaled amounts can consume the entire scaled balance even when the unscaled arithmetic predicts a small leftover. This means `_burnDebtTokens` may proceed with `hasNoCollateralLeft == false` while the collateral is fully depleted.

Impact:

Low. The mismatch does not pose a direct danger to the protocol, it only affects the automatic detection of bad debt during liquidation. Even in the unlikely scenario where bad debt goes unrealized due to this bug, it can be manually triggered via a dust donation followed by another liquidation.

Recommendation:

Compute the scaled collateral consumed using the same `rayDivCeil` rounding as the actual burn/transfer paths, cap it to the scaled balance, then derive the consumed base-currency value from the effective scaled amount.

Developer Response:

Fixed in commit `75145ad`. BGD reworked the `hasNoCollateralLeft` detection to use the same `rayDivCeil` rounding as the actual transfer paths, with the scaled consumption capped to the scaled balance.

Informational

I-01 - Minor improvements to code and comments

Severity: Informational

Context: See below.

Technical Details/Recommendations:

1. IPoolConfigurator.sol#L230: The `BridgeProtocolFeeUpdated` event should be removed, as it was deprecated in a previous update and is no longer in use.
2. ReserveConfiguration.sol#L21: The removed mask is missing a bit hole comment, inconsistent with how prior deprecations were handled (e.g., eModeCategory, unbackedMintCap).
3. IAaveV3ConfigEngine.sol#L210-L211: The `EModeCategoryUpdate` example comment is missing the isolated flag.
4. IPool.sol#L792-L793: Single-asterisk comment (*/) used instead of NatSpec-compliant double-asterisk (/**), causing the @notice/@dev/@param tags to be ignored by the compiler.
5. IDefaultInterestRateStrategyV2.sol#L89, IDefaultInterestRateStrategyV2.sol#L98: Notice tag is missing the @ prefix, causing it to not be recognized as a valid NatSpec tag. @notice comment says "InterestRateDataRay" but the function returns InterestRateData in bps.
6. ValidationLogic.sol#L4-L33: Unused imports (`Address` , `GPv2SafeERC20` , `SafeCast`) and their corresponding using declarations (L28-L32) can be removed.
7. IPoolConfigurator.sol#L427-L433: `setAssetLtvzeroInEMode` NatSpec describes enabling/disabling "collateral" instead of the ltvzero flag.

Developer Response:

Fixed in commit `73e03ff`.

Fixed. The fixes have been verified by the Enigma Dark team.

Disclaimer

This report does not endorse or critique any specific project or team. It does not assess the economic value or viability of any product or asset developed by parties engaging Enigma Dark for security assessments. We do not provide warranties regarding the bug-free nature of analyzed technology or make judgments on its business model, proprietors, or legal compliance.

This report is not intended for investment decisions or project participation guidance. Enigma Dark aims to improve code quality and mitigate risks associated with blockchain technology and cryptographic tokens through rigorous assessments.

Blockchain technology and cryptographic assets inherently involve significant risks. Each entity is responsible for conducting their own due diligence and maintaining security measures. Our assessments aim to reduce vulnerabilities but do not guarantee the security or functionality of the technologies analyzed.

This security engagement does not guarantee against a hack. It is a review of the codebase during a specific period of time. Enigma Dark makes no warranties regarding the security of the code and does not warrant that the code is free from defects. By deploying or using the code, the project and users of the contracts agree to use the code at their own risk. Any modifications to the code will require a new security review.